AUDIT REPORT

AUDITRA

IT Audit & Compliance Report v2.1

50/100

Medium Risk

Audit Information

ORGANIZATION Amirthaa Kids Playschool	TYPE Playschool / Kindergarten
AUDITOR Vasuntthara D (IT Compliance Officer)	DATE & LOCATION 20-03-2026 | Karaikudi, Tamil Nadu
STAFF COUNT 8	DEVICES 4
PRIMARY CONCERN Data Privacy & Protection	PREVIOUS AUDIT No

Notes: First IT audit for this playschool. Focus on data security, device management and regulatory compliance.

Results Summary

4	7	4	27%
Compliant	Partial	Non-Compliant	Compliance Rate

Detailed Findings

#	QUESTION	CATEGORY	RESPONSE	SEVERITY
1	Do you store student/client data digitally?	Data Management	Yes	Low
2	Is all stored data password protected?	Data Security	Partial	Medium
3	Are system passwords changed regularly (every 90 days)?	Password Policy	Partial	Medium
4	Is antivirus software installed and up-to-date on all devices?	Endpoint Security	Partial	Medium
5	Are operating systems and software regularly updated/patched?	Patch Management	Partial	Medium
6	Do you take regular automated backups of important data?	Backup & Recovery	No	Critical
7	Is system/data access restricted to authorized staff only?	Access Control	Yes	Low
8	Do you use only licensed/genuine software on all devices?	Software Compliance	Yes	Low
9	Is the office WiFi secured with a strong WPA2/WPA3 password?	Network Security	Yes	Low
10	Is CCTV footage access restricted and stored securely?	Physical Security	Partial	Medium
11	Are USB / removable devices controlled or restricted?	Device Control	Partial	Medium
12	Is sensitive data shared securely (not via WhatsApp/personal email)?	Data Sharing	No	Critical
13	Is sensitive/personal data encrypted at rest and in transit?	Data Encryption	Partial	Medium
14	Is there a documented incident response/breach plan?	Incident Response	No	Critical
15	Are devices automatically locked after inactivity?	Endpoint Security	No	Critical

⚖️ Regulation & Compliance Violations

⚠️ DPDP Act 2023 (India)

→ Section 8 – Obligations of Data Fiduciary: Unprotected personal data violates data security obligations.
→ Section 8(6) – Data Accuracy & Integrity: No backup plan risks permanent loss of personal data, violating data integrity obligations.
→ Section 4 – Lawful Recording: CCTV footage of individuals is personal data and must be protected.
→ Section 8(3) – Data Confidentiality: Sharing personal data via WhatsApp or insecure channels violates confidentiality obligations.
→ Section 8(3) – Security Safeguards: Unencrypted personal data is a direct violation of data security obligations.
→ Section 8(6) – Breach Notification: No IRP means inability to notify Data Protection Board of breaches as required.

⚠️ ISO/IEC 27001:2022

→ A.8.1 – User Endpoint Devices: Unprotected data storage violates asset management requirements.
→ A.9.4 – System & Application Access Control: Infrequent password changes increase risk of unauthorized access.
→ A.8.8 – Management of Technical Vulnerabilities: Missing antivirus exposes endpoints to malware and ransomware attacks.
→ A.8.8 – Technical Vulnerability Management: Unpatched systems are a primary attack vector and ISO violation.
→ A.8.13 – Information Backup: Absence of backup policy directly violates ISO 27001 backup requirements.
→ A.7 – Physical & Environmental Controls: Unsecured CCTV access violates physical security access controls.
→ A.8.12 – Data Leakage Prevention: Uncontrolled USB devices are a primary data exfiltration vector.
→ A.8.24 – Use of Cryptography: Absence of encryption violates the cryptography control requirement.
→ A.5.24 – Incident Management: ISO 27001 requires documented incident response planning and procedures.
→ A.8.1 – User Endpoint Devices: Unattended unlocked devices risk unauthorized access to personal data.

⚠️ IT Act 2000 (India)

→ Section 43A: No password protection constitutes failure to implement reasonable security practices.
→ Section 43A: No backup constitutes failure to implement reasonable security practices.
→ Section 43A – SPDI: Insecure transmission of sensitive personal data is an SPDI rules violation.
→ Section 43A: No encryption of sensitive data violates reasonable security practices.

⚠️ NIST CSF 2.0

→ PR.AC – Identity Management: Failure to rotate credentials violates identity management best practices.
→ PR.DS – Data Security: Unprotected endpoints violate data security protection requirements.
→ PR.DS – Data Security: Uncontrolled removable media violates data security protection standards.
→ RS – Respond Function: The entire Respond function requires an incident response plan.
→ PR.AC – Identity Management & Access Control: Devices not auto-locking fail the access control protection principle.

💡 Recommendations

🟡 **Is all stored data password protected?**
Enforce strong password policies (min 12 chars, alphanumeric+symbols). Encrypt all stored personal data immediately.

🟡 **Are system passwords changed regularly (every 90 days)?**
Set up mandatory 90-day password rotation. Use a password manager. Enable MFA where possible.

🟡 **Is antivirus software installed and up-to-date on all devices?**
Deploy reputable endpoint protection (Windows Defender, Malwarebytes, or equivalent) on ALL devices. Schedule weekly scans.

🟡 **Are operating systems and software regularly updated/patched?**
Enable automatic OS and software updates. Review pending patches weekly. Prioritize critical/security patches.

🔴 **Do you take regular automated backups of important data?**
Implement 3-2-1 backup: 3 copies, 2 media types (local + cloud), 1 offsite. Test restores quarterly.

🟡 **Is CCTV footage access restricted and stored securely?**
Restrict CCTV system access to authorized personnel only. Log all access. Encrypt stored footage. Review retention policy.

🟡 **Are USB / removable devices controlled or restricted?**
Deploy endpoint management to block unauthorized USB devices. Use Group Policy or dedicated DLP tools.

🔴 **Is sensitive data shared securely (not via WhatsApp/personal email)?**
Stop using WhatsApp/personal email for any organizational data. Use encrypted channels: Signal for Business, email with TLS, or secure file-sharing platforms.

🟡 **Is sensitive/personal data encrypted at rest and in transit?**
Encrypt all sensitive files with AES-256. Use BitLocker (Windows) or FileVault (Mac) for disk encryption. Use TLS 1.3 for all data transmission.